



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

Всем доброго времени суток!

Обнаружение уязвимостей является неотъемлемой частью любой оценки безопасности. Хотя мы предпочитаем ручные методы, наши знания и опыт во время аудита безопасности, автоматические сканеры уязвимостей, тем не менее, бесценны при использовании в правильном контексте. В этом разделе мы обсудим автоматизированное сканирование уязвимостей, обсудим его различные аспекты и остановимся на [OWASP ZAP](#) и Nmap как на незаменимых инструментах.



Прежде чем погрузиться в изучение непосредственно инструментов, мы должны уделить некоторое время обсуждению процесса сканирования уязвимостей, сформировать основные соображения относительно автоматического и ручного сканирования, а также обсудить нюансы и лучшие практики сканирования.

Как работают сканеры уязвимостей

Большинство автоматических сканеров:

1. Определяют, работает ли цель.
2. Проводят полное или частичное сканирование портов, в зависимости от конфигурации.
3. Определяют операционную систему, используя обычные методы снятия "отпечатков пальцев".
4. Пытаются определить запущенные службы с помощью таких распространенных методов, как захват баннеров, определение поведения служб или обнаружение файлов.
5. Выполняют процесс сопоставления сигнатур. Обратите внимание, что этот процесс в основном повторяет то, что мы делаем во время ручной оценки. Как тестеры проникновения, мы должны регулярно выполнять тот или иной процесс сопоставления сигнатур.

Например, мы можем помнить, что определенная версия приложения, которую мы обнаружили в полевых условиях, уязвима для удаленного [эксплойта](#). Автоматический сканер выполняет этот шаг с помощью уникальных сигнатур уязвимостей. Как часть процесса подбора сигнатур,

многие сканеры используют захват баннеров - простую технику, при которой текстовые строки, созданные во время первоначального взаимодействия с приложением, получают и анализируют. Некоторые приложения генерируют очень специфические баннеры, такие как OpenSSH, который может вернуть "SSH-2.0-OpenSSH_7.9p1 Debian-10", что позволяет нам точно определить версию приложения, в то время как другие, такие как Apache Tomcat версий от 4.1.x до 8.0.x, возвращают общий HTTP-заголовок "Apache-Coyote/1.1". Естественно, более конкретные заголовки и баннеры облегчают сканеру определение версии приложения и, соответственно, точное обнаружение потенциальных уязвимостей.

P.S. Некоторые сканеры уязвимостей могут быть настроены на эксплуатацию уязвимости при ее обнаружении. Это может снизить вероятность ложного обнаружения, но повышает риск сбоя самой службы. Всегда тщательно проверяйте параметры сканера.

Большинство автоматических сканеров проверяют широкий спектр информации о цели в процессе сопоставления сигнатур. Тем не менее, даже сильное совпадение сигнатур не гарантирует наличие уязвимости. Это означает, что автоматические сканеры могут генерировать довольно много ложных срабатываний. И, напротив, ложных отрицаний, когда уязвимость не обнаруживается из-за несовпадения сигнатур.

Ложные срабатывания и ложные отрицания могут также возникать из-за [бэкпортирования](#), при котором разработчики "откатывают" исправления безопасности программного обеспечения на более старые версии. Бэкпортирование может привести к тому, что сканер будет отмечать программное обеспечение как уязвимую версию, когда на самом деле уязвимость была устранена.

В связи с этим следует тщательно проверять и вручную анализировать результаты сканирования уязвимостей, когда это возможно. Учитывая постоянно меняющийся и сложный технологический "ландшафт", уязвимости могут появляться в неожиданных местах. Как бы ни были хороши некоторые из лучших коммерческих сканеров, ни один из них не является идеальным. Однако, обновляя базу данных сигнатур перед каждой работой, мы можем быть уверены, что наш сканер имеет хорошие шансы обнаружить новейшие уязвимости. Этот процесс сопоставления сигнатур достаточно эффективен и намного быстрее, чем полностью ручная проверка, что делает автоматические сканеры уязвимостей отличным выбором в качестве

"первого прохода" во время оценки и прекрасным дополнением к ручной проверке.

Ручное или автоматическое сканирование?

В процессе оценки следует сочетать ручные и автоматические методы сканирования. Давайте обсудим основные преимущества и недостатки ручного и автоматизированного сканирования для того, чтобы помочь найти правильный баланс во время оценки. Ручное сканирование удаленной целевой сети неизбежно требует больших ресурсов и времени. Поскольку этот подход в значительной степени зависит от взаимодействия с человеком и повторяющихся задач, он также склонен к ошибкам, в результате которых уязвимые места могут быть упущены. Тем не менее, для того чтобы оставаться незамеченным как можно дольше, требуется хирургическая точность и минимальный сетевой след. Использование автоматизированного сканера в таких ситуациях было бы не самым лучшим подходом. Более того, ручной анализ позволяет обнаружить сложные уязвимости, которые довольно сложно обнаружить с помощью любого типа автоматизированного сканера. Однако автоматические сканеры уязвимостей неоценимы при работе над крупными проектами в условиях типичных ограничений по времени, связанных с традиционной оценкой безопасности.

Сканирование через Интернет или внутреннее сканирование?

Сканеры уязвимостей могут легко сканировать цели, подключенные к Интернету, а также цели, подключенные к локальной сети. Расположение нашей сети по отношению к цели может повлиять на порог скорости, права доступа и видимость цели. Скорость нашего подключения к целевой сети диктует не только пропускную способность, доступную нашему сканеру, но и другие факторы, такие как, например, количество [хопов](#) до отдельных узлов. Это означает, что мы можем быстрее проводить более интрузивное и всестороннее сканирование узлов, подключенных к локальной сети. Однако мы должны постоянно следить за трафиком, понимая, что старое оборудование может пострадать от интенсивного сканирования.

Для достижения оптимальных результатов учитывайте рекомендации, сформулированные [в уроке про сканирование портов](#) в предыдущем разделе.

Наше местоположение в сети также может повлиять на наши права доступа. Например, брандмауэры или [системы предотвращения вторжений \(IPS\)](#) могут блокировать наш доступ к узлам или портам и могут отбрасывать наш трафик, генерируя при этом предупреждения о безопасности. Эти устройства ограничивают наши возможности и как результат прячут уязвимости цели за ними, что негативно скажется на конечном продукте, который мы предоставляем нашему клиенту. Наконец, наше сетевое позиционирование может повлиять на видимость целей. Например, типичный сканер уязвимостей пытается обнаружить цели с помощью ping-сканирования или ARP-сканирования. Однако, цели, подключенные к Интернету, могут блокировать ICMP (ping) запросы из внешних подсетей, что означает, что сканер может полностью пропустить цели, если он настроен полагаться только на эти варианты обнаружения.

Мы должны потратить время на то, чтобы тщательно изучить целевую сеть, точное местоположение сети, из которого мы будем работать, и доступ к цели, который обеспечивает наше сетевое позиционирование.

Аутентифицированное или неаутентифицированное сканирование?

Большинство сканеров можно настроить на выполнение аутентифицированного сканирования, при котором сканер входит в систему цели с определенными учетными данными. В большинстве случаев аутентифицированное сканирование использует учетную запись привилегированного пользователя, чтобы обеспечить наилучшую видимость целевой системы.

Чтобы запустить аутентифицированное сканирование на объекте Linux, достаточно включить службу [SSH](#) на объекте Linux и настроить сканер с действительными учетными данными пользователя. Большинство сканеров используют этот доступ для проверки конфигураций в попытке обнаружить потенциальные уязвимости. Для аутентификации Windows обычно требуется инструмент управления [Windows Management Instrumentation \(WMI\)](#), а также учетные данные доменной или локальной учетной записи с правами

удаленного управления. Обратите внимание, что даже при настроенном WMI, другие факторы могут блокировать аутентификацию, такие как [UAC](#) и настройки брандмауэра.

Однако после того, как доступ настроен должным образом, большинство сканеров анализируют конфигурацию системы, параметры реестра, уровни исправлений приложений и системы. Они также просматривают файлы в каталогах Program Files, а также все исполняемые файлы и библиотеки DLL в папке Windows, пытаясь обнаружить потенциально уязвимое программное обеспечение. Аутентифицированное сканирование в отличие от не аутентифицированного, генерирует большое количество дополнительной информации и дает более точные результаты за счет более длительного времени сканирования.